

A FIELD HISTORY FOR BUILDERS AND HOLDERS

Keys in Hand

A History of Cryptocurrency Hardware Wallets

The thefts that created the industry, the companies that built it, and the costly mistakes made by vendors, developers, and users along the way.



WHO THIS IS FOR

Engineers building firmware, companion apps, dApp connectors, or signing flows that touch hardware wallets, and anyone holding meaningful value on one. Every incident here is real, and most were preventable.

Current through October 2026. Figures for recent incidents are preliminary and may change.

Contents

1. Why Read a History of Hardware Wallets?	3
2. Before Hardware Wallets: The Thefts That Created the Need (2009 to 2014)	3
June 2011: The "allinvain" theft	3
June 2011 and February 2014: Mt. Gox	4
March 2012: The Linode heist and the birth of Trezor	4
3. Origins of the Major and Earliest Players	5
SatoshiLabs and Trezor (Prague, Czech Republic)	5
Ledger (Paris and Vierzon, France)	5
KeepKey (Kirkland, Washington, USA)	6
Coinkite and Coldcard (Toronto, Canada)	6
Two design philosophies	6
Timeline at a Glance	7
4. When the Device Itself Was the Weak Link	8
2018: Breaking Ledger's two-chip trust model	8
2018 to 2022: Fault injection against open microcontroller wallets	8
2024: Dark Skippy and the malicious-firmware problem	9
2026: The Coldcard entropy failure, the largest hardware wallet exploit on record	9
5. When the Company and Its Ecosystem Were the Weak Link	10
Customer data: a list of targets	10
Software supply chain: the code that talks to the device	12
Trust and communication: Ledger Recover, May 2023	12
6. When the Human and Operational Layer Was the Weak Link	13
Bybit, February 2025: \$1.5 billion signed on hardware wallets	13
Seed phishing and the never-type-your-seed rule	14
Loss without theft	14
Address verification and the compromised host	14
7. Consolidated Lessons for Builders	14
8. Consolidated Lessons for Holders	15
Closing Thought	16
9. Sources	17

1. Why Read a History of Hardware Wallets?

A hardware wallet is a small, single-purpose computer whose job is to hold private keys and sign transactions without ever exposing those keys to the internet-connected machine it is plugged into. That sentence sounds simple, and the marketing that grew around it ("your keys never leave the device") made it sound simpler still. The real history is messier. Hardware wallets were invented as a direct response to theft, and nearly every improvement since has been a response to a new way that keys, seeds, or signatures were stolen, guessed, phished, or tricked out of people.

This document is written for two audiences who need the same history for different reasons. If you build firmware, companion apps, browser connectors, dApp front ends, or custody systems that rely on hardware signers, the incidents below are a catalog of failure modes that have already cost real people real money; most of them could recur in your code. If you hold meaningful value on a hardware wallet, the same incidents show where the actual risk lives, which is usually not where people expect it.

The document moves roughly chronologically. Section 2 covers the thefts that created demand for hardware wallets. Section 3 explains where the earliest and largest manufacturers came from. Sections 4 through 6 group incidents by where the weak link was: the device itself, the company and its software ecosystem, or the human and operational layer around the device. Sections 7 and 8 distill the lessons, and Section 9 lists sources.

A NOTE ON NUMBERS

Dollar figures are given at the value reported at the time of each incident. For events in 2026, tallies from on-chain analysts were still changing at the time of writing and should be treated as preliminary. Where sources disagree, the range or the most conservative widely cited figure is used.

2. Before Hardware Wallets: The Thefts That Created the Need (2009 to 2014)

In Bitcoin's first years, a wallet was a file. The reference client stored private keys in a file called `wallet.dat` on the user's general-purpose computer, and early versions did not encrypt it. Anyone or anything that could read that file could spend the coins. The security model of an early Bitcoin holder was therefore exactly as strong as the security of a Windows desktop that was also used for email, browsing, and downloading software. Wallet encryption was added to the reference client in version 0.4.0 in September 2011, but by then the pattern of loss was established.

June 2011: The "allinvain" theft

On June 13, 2011, a Bitcointalk forum user known as allinvain posted that he had woken up to find roughly 25,000 BTC gone from his wallet, then worth about \$500,000. He was an early miner who had accumulated coins through Slush's mining pool, and the coins sat in an unencrypted wallet file on a Windows machine he used every day. The authenticity of the story was debated at the time, but the on-chain movement was real, and within days the security firm Symantec described a trojan (Infostealer.Coinbit) built specifically to find and exfiltrate Bitcoin wallet files. Malware authors had discovered that a single file on a home computer could be worth more than an entire bank account.

June 2011 and February 2014: Mt. Gox

The same month, the largest exchange of the era, Mt. Gox, was breached. An attacker used a compromised account to dump coins on the order book, briefly crashing the price on the exchange to a few cents, and a user database leaked. That incident was survivable. The second was not. In February 2014 Mt. Gox halted withdrawals and filed for bankruptcy, reporting roughly 850,000 BTC missing (about 200,000 were later found). The collapse taught a generation of users the phrase "not your keys, not your coins" and drove many of them to look for a way to hold their own keys safely. KeepKey's founder later cited Mt. Gox as the direct motivation for his company.

March 2012: The Linode heist and the birth of Trezor

On March 1, 2012, an attacker abused access to the customer-support systems of the hosting provider Linode to take over servers belonging to several Bitcoin businesses. About 46,703 BTC were stolen in total. The trading platform Bitcoinica lost about 43,554 BTC; Gavin Andresen's Bitcoin Faucet lost 5 BTC; and the mining pool operated by Marek "Slush" Palatinus lost 3,094 BTC from its hot wallet. Trezor's own published history points to this attack as one of the events that shaped the product: the man who would co-found the first commercial hardware wallet had personally watched keys stored on an internet-connected server get emptied through a provider he did not control.

Bitcoinica's troubles continued that year. A second breach in May 2012 came through a compromised email account, and a third in July drained an exchange account after a reused password exposed a password manager. The common thread across all of these incidents was the same: private keys, or credentials that unlocked them, lived on general-purpose machines and accounts that had many other ways to be compromised.

LESSON FOR BUILDERS

The founding problem of this industry was that general-purpose computers are a terrible place to keep a secret that is directly convertible into money. Every design decision in a hardware wallet traces back to shrinking the amount of code and the number of people who can touch the key. When you add features, connectivity, cloud services, or dependencies around a hardware signer, you are re-expanding the attack surface the device was created to shrink.

3. Origins of the Major and Earliest Players

Several people sketched hardware-signing concepts in the early 2010s, and smart-card experiments existed, but three companies define the commercial origin of the category: SatoshiLabs (Trezor), Ledger, and KeepKey. A fourth, Coinkite (Coldcard), became the reference point for air-gapped Bitcoin-only signing. Their origin stories matter because each made an early architectural bet that shaped the vulnerabilities and incidents that followed.

SatoshiLabs and Trezor (Prague, Czech Republic)

Pavol "Stick" Rusnák and Marek "Slush" Palatinus met in 2011 at brmlab, a hackerspace in Prague. Palatinus already ran Slush Pool, widely recognized as the first Bitcoin mining pool (launched in 2010). The pair began working on a small dedicated device for holding Bitcoin keys, completed a prototype in 2012, founded SatoshiLabs in 2013, and announced and crowdfunded the device that year. The Trezor One reached customers in mid-2014, which is why Trezor describes itself as the first commercial hardware wallet.

Trezor's lasting contributions go well beyond its own product. Rusnák and Palatinus co-authored BIP39 (the standard for encoding a wallet seed as a list of human-readable words) and BIP44 (a standard structure for deriving many accounts from one seed). SatoshiLabs later published SLIP39 for splitting a backup into shares. The 12- or 24-word recovery phrase that nearly every wallet uses today is a Trezor-era invention.

Trezor's architectural bet was radical openness: open-source firmware and hardware designs running on a general-purpose STM32 microcontroller rather than a closed "secure element" chip that requires a non-disclosure agreement with the chip vendor. This made the code fully auditable, and it also meant the seed was stored in ordinary microcontroller flash, protected by the chip's read-out protection. As Section 4 shows, that protection could be defeated with fault injection by an attacker holding the device. Trezor later introduced secure-element chips in its Safe-series devices while keeping its firmware open.

Ledger (Paris and Vierzon, France)

Ledger was formed in 2014 by merging several French Bitcoin projects under a group of eight co-founders. Nicolas Bacca, a smart-card security engineer, had created BTChip, an early secure-element hardware wallet (the HW.1 dongle) that served as the technical precursor to Ledger's products. Eric Larchevêque had opened La Maison du Bitcoin, a Paris storefront for buying bitcoin, in 2014. Thomas France had founded Chronocoin, a card-based bitcoin purchase service. These merged into Ledger, with other co-founders including Joël Pobeda and David Balland. Larchevêque served as CEO until Pascal Gauthier took over in 2019.

Ledger's first Nano shipped at the end of 2014. The Nano S, released in July 2016, became the company's breakout product during the 2017 bull market, and the Bluetooth-capable Nano X followed in 2019. Ledger's architectural bet was the opposite of Trezor's: keys live inside a certified secure element (the same family of tamper-resistant chips used in bank cards and passports), with a separate general-purpose microcontroller handling the screen, buttons, and USB. Secure elements resist the glitching attacks that hurt open microcontroller designs, but their firmware is largely closed, and the two-chip arrangement created its own trust boundary that a researcher broke in 2018.

KeepKey (Kirkland, Washington, USA)

Darin Stanchfield founded KeepKey in 2014 in the Seattle area, explicitly in response to the Mt. Gox collapse, with Ken Hodler as CTO. The device launched in 2015 with a larger screen and a premium aluminum body. Its firmware was derived from Trezor's open-source codebase and ran on the same family of STM32 microcontroller, which is why hardware attacks against one later applied to the other. KeepKey acquired the MultiBit desktop wallet in 2016 and was itself acquired by the exchange ShapeShift in 2017, which integrated on-device swaps. When ShapeShift reorganized as a DAO in 2021, KeepKey was spun back out as an independent company.

Coinkite and Coldcard (Toronto, Canada)

Coinkite, founded in Toronto in the early 2010s by Rodolfo Novak and Peter D. Gray, began as a web-based Bitcoin wallet and payments company. In 2016 it shut down its web wallet and pivoted entirely to hardware, first releasing Opendime, a single-use bitcoin "bearer stick." Coinkite announced the Coldcard in December 2017 and shipped it in 2018. Coldcard was Bitcoin-only and built around air-gapped signing: rather than talking to a computer over USB, it could exchange Partially Signed Bitcoin Transactions (PSBT, BIP174) on a microSD card. Gray was an active participant in the PSBT standardization discussion, and Coldcard helped make PSBT the interoperability standard it is today. Its firmware is built on MicroPython, a detail that became central to the largest hardware wallet exploit on record (Section 4).

Two design philosophies

	Open microcontroller (early Trezor, KeepKey)	Secure element (Ledger, later most vendors)
Where the seed lives	Flash memory of a general-purpose MCU, behind read-out protection	Inside a tamper-resistant certified chip
Main strength	Fully auditable firmware and hardware; no vendor NDA	Strong resistance to physical extraction and fault injection
Main weakness	Physical attackers with the device can glitch the chip and extract the seed	Closed chip firmware; trust shifts to the vendor and the chip supplier
How it was exploited	Voltage glitching (2019 to 2022)	Trust boundary between SE and display MCU (2018); vendor software and services

Over time the camps converged. Most current devices pair a secure element with open or partially open firmware, and the real differentiators shifted to how well a device shows the user what is being signed, how its seed is generated, and how much trust it places in the host computer and the company's online services.

Timeline at a Glance

Date	Event	Category
Jun 2011	allinvain loses ~25,000 BTC from an unencrypted wallet file; Mt. Gox breached	Pre-hardware theft
Mar 2012	Linode breach: ~46,703 BTC stolen, incl. 3,094 BTC from Slush Pool	Pre-hardware theft
2012 to 2013	Trezor prototype built; SatoshiLabs founded; crowdfunding	Origins
Feb 2014	Mt. Gox collapses with ~850,000 BTC reported missing	Pre-hardware theft
2014	Trezor One ships; Ledger formed from BTChip, La Maison du Bitcoin, Chronocoin; KeepKey founded	Origins
2015	KeepKey ships	Origins
Jul 2016	Ledger Nano S released	Origins
Dec 2016	KeepKey CEO's phone account hijacked; company accounts and customer data exposed	Company
2017 to 2018	ShapeShift acquires KeepKey; Coldcard announced and shipped	Origins
Mar 2018	Saleem Rashid breaks Ledger Nano S MCU verification (supply-chain attack)	Device
Dec 2018	wallet.fail talk at 35C3 demonstrates attacks on several major wallets	Device
Dec 2019 to Jan 2020	Kraken Security Labs glitches KeepKey and Trezor to extract seeds	Device
Jun to Dec 2020	Ledger e-commerce/marketing data breach; ~272,000 home addresses leaked	Company
Jun 2021	Fake Ledger Nano X devices with USB implants mailed to breach victims	Company / user
Jan 2022	Joe Grand publishes recovery of ~\$2M from a Trezor One via glitching	Device
May 2023	Ledger Recover announcement triggers trust backlash	Company
Nov 2023	Fake Ledger Live app on Microsoft Store linked to ~\$768,000 in losses	Ecosystem
Dec 2023	Ledger Connect Kit npm supply-chain attack; ~\$600,000 drained	Ecosystem
Jan 2024	Trezor third-party support portal breached; up to 66,000 contacts exposed	Company
Aug 2024	Dark Skippy seed-exfiltration technique disclosed	Device
Jan 2025	Ledger co-founder David Balland kidnapped and held for ransom in France	Physical
Feb 2025	Bybit loses ~\$1.5B after signers approve a disguised transaction on hardware wallets	Operational
Jul to Aug 2026	Coldcard weak-entropy bug exploited; ~1,816 BTC (~\$116M) drained	Device
Aug to Sep 2026	Trezor customer data exposed via shipping vendor; phishing sent via compromised email vendor	Company

4. When the Device Itself Was the Weak Link

These incidents involve the hardware or firmware failing to protect the key. Several required physical access to the device, which matters for threat modeling; one did not, and it was by far the most expensive.

2018: Breaking Ledger's two-chip trust model

In March 2018, Saleem Rashid, then a 15-year-old security researcher in the United Kingdom, published an attack on the Ledger Nano S. The Nano S kept keys in a secure element but used a separate, non-secure STM32 microcontroller to drive the screen and buttons. The secure element was supposed to verify that the microcontroller was running genuine Ledger firmware by asking it to send back the contents of its memory. Rashid showed that the check could be fooled, so a modified microcontroller could pass as genuine while controlling what the user saw. In a supply-chain scenario (for example, a tampered unit sold by a third-party reseller), the device could generate a recovery seed the attacker already knew.

Rashid reported that Ledger initially dismissed the finding as impractical. Ledger fixed the issue in Nano S firmware 1.4.1, released in early March 2018, and later credited Rashid in its security bulletin. The episode had two lasting lessons: a secure element only protects what it can actually verify, and how a company responds to researchers is part of its security posture.

2018 to 2022: Fault injection against open microcontroller wallets

At the 35C3 conference in December 2018, researchers Thomas Roth, Dmitry Nedospasov, and Josh Datko presented "wallet.fail," demonstrating attacks against several popular wallets. Ledger's own security lab, Ledger Donjon, published research on Trezor in 2019. Then in December 2019 and January 2020, Kraken Security Labs disclosed that it could extract the encrypted seed from KeepKey and from both the Trezor One and Trezor Model T using voltage glitching: briefly disturbing the chip's power supply at a precise moment during boot to bypass its read-out protection. With the encrypted seed in hand, the PIN protecting it could be brute-forced quickly. Kraken said the attack took about 15 minutes of physical access and estimated that a consumer-friendly glitching tool could be built for under \$100.

Trezor acknowledged that the flaw lived in the STM32 silicon itself and could not be fully fixed by firmware. Its main mitigation advice was to use a BIP39 passphrase, an extra secret that is never stored on the device, so that extracting the stored seed is not enough to reach the funds.

The same weakness was later used for good. In 2021, hardware hacker Joe Grand ("Kingpin") recovered roughly \$2 million in THETA tokens for an owner who had lost the PIN to a Trezor One running older firmware. Grand used fault injection to downgrade the chip's protection and exploited the fact that this firmware version copied, rather than moved, sensitive data into RAM during an update. He published the story in January 2022. For every user who cheered the recovery, the uncomfortable corollary was that a thief with the same skills could do the same thing.

LESSON FOR BUILDERS

Assume an attacker will eventually hold your device. Do not let a short PIN be the only thing standing between a stolen device and the seed. Store secrets in hardware designed to resist fault injection where possible, audit every code path that copies secrets (update and recovery paths are frequent culprits), and support a passphrase or similar secret that is never persisted on the device.

2024: Dark Skippy and the malicious-firmware problem

In August 2024, Lloyd Fournier, Nick Farrow, and Robin Linus disclosed "Dark Skippy," a technique a malicious signing device can use to leak its seed through ordinary transaction signatures. Every ECDSA or Schnorr signature requires a secret random number called a nonce. Corrupted firmware can choose deliberately weak nonces that encode pieces of the seed. An attacker watching the blockchain can then recover those nonces and reassemble the seed from as few as two signatures, potentially from a single transaction with two inputs. The device never needs a network connection, and the signatures look normal to the user.

The researchers disclosed privately to roughly 15 vendors before publishing. The attack requires corrupted firmware or hardware, so it is fundamentally a supply-chain and update-integrity problem. Its defenses include verifiable, reproducibly built firmware; deterministic nonces (RFC 6979), which eliminate accidental nonce weaknesses though not deliberate ones; "anti-exfil" signing protocols in which the host contributes randomness the device cannot control (Blockstream's Jade has shipped such a protocol since 2021); and multisig across independent devices.

2026: The Coldcard entropy failure, the largest hardware wallet exploit on record

On July 30, 2026, an attacker began sweeping bitcoin out of single-signature wallets in coordinated waves. The first wave moved roughly 594 BTC from about 500 wallets in under half an hour. The same day, Coinkite warned Coldcard owners that seeds created on certain firmware might be unsafe. By early August, Galaxy Research's running tally (cited by TRM Labs) stood near 1,816 BTC, about \$116 million, drained from more than 5,200 addresses across four waves. No device was stolen, nobody was phished, and nothing leaked. The seeds were simply guessable.

The root cause was a build-configuration error introduced in firmware 4.0.1 in March 2021. Coldcard's firmware runs on MicroPython, and Coinkite deliberately set the MicroPython configuration flag `MICROPY_HW_ENABLE_RNG` to zero because it supplied its own wrapper around the chip's hardware random number generator. When a new cryptographic support library was later pulled in, the seed generation path ended up relying on MicroPython's software fallback generator instead, which was seeded from predictable values such as the chip's unique ID and timer registers. Coinkite estimated effective entropy at roughly 40 bits on the Mk3 and about 72 bits on the Mk4, Mk5, and Q, against the 128 bits a 12-word seed is supposed to have. A 40-bit space can be searched with ordinary computing resources.

Coinkite shipped patched firmware for every affected model within about a day. But a firmware update cannot repair a seed that was already generated weakly; affected owners had to create a new seed on patched firmware and move their coins, ideally before an attacker reached their addresses. Coinkite noted that seeds created from at least 50 fair, private dice rolls were not at risk from this bug alone. The flaw sat in public,

open-source code for over five years without being caught, which is a sobering data point for anyone who treats "open source" as equivalent to "audited."

Nor was this the first time weak entropy emptied wallets. In 2023, the "Milk Sad" disclosure showed that the Libbitcoin Explorer command-line tool had generated seeds from a generator seeded with only 32 bits of system time, and funds were stolen from wallets created with it. The pattern is consistent: entropy failures are silent, they pass every functional test, and they are exploited remotely and at scale.

LESSON FOR BUILDERS

Seed generation is the single most important function your device performs, and the hardest one to test because broken randomness still produces valid-looking seeds. Treat build configuration as security-critical code. Add tests that fail if the hardware RNG is not actually being called on the seed-generation path (for example, by instrumenting or mocking the TRNG in test builds). Mix multiple independent entropy sources, offer user-supplied dice entropy, re-review RNG paths whenever a dependency changes, and have a plan for telling users to migrate seeds, because a firmware patch alone does not protect them.

LESSON FOR HOLDERS

Ask how your seed was created, not just where it is stored. A seed generated by a flawed process stays flawed forever, no matter how many times you update the device. Multisig that combines devices from different vendors, each generating its own seed, would have contained the Coldcard failure to one key out of several.

5. When the Company and Its Ecosystem Were the Weak Link

A hardware wallet company holds two things attackers want even if it never touches a single private key: a list of people who probably own cryptocurrency, and software that those people trust to talk to their devices. Many of the most damaging incidents in this history exploited one or the other.

Customer data: a list of targets

KeepKey, 2016.

Around Christmas 2016, an attacker social-engineered KeepKey's CEO's mobile phone account, used it to take over his email, and from there reached company accounts and customer information. It was an early warning that the people who run a wallet company are themselves high-value targets, and that phone-number-based account recovery is a weak link.

Ledger, 2020 to 2021.

In July 2020 a researcher reported through Ledger's bounty program that an unauthorized party had accessed its e-commerce and marketing database. Ledger's own forensic review found that more than one million email addresses had been taken, and in December 2020 the full data set was dumped publicly on a hacking forum, revealing about 272,000 customer records with names, postal addresses, and phone numbers. Ledger later learned from Shopify that rogue members of Shopify's support team had separately exposed roughly 20,000 more records, bringing the total to about 292,000 detailed records.

The consequences unfolded over years. Customers were hit with waves of phishing emails and SMS messages directing them to fake Ledger Live software that asked for their recovery phrase. Some received extortion emails threatening home invasion unless they paid. SIM-swap attempts followed. In June 2021, some victims received physical packages containing a convincingly shrink-wrapped Ledger Nano X box and a letter, purportedly from Ledger's CEO, explaining that this was a replacement device for their security. Inside was a real Nano X with a small USB flash drive soldered onto its board, loaded with a fake Ledger Live app that asked the victim to type in their 24 words. In January 2025, Ledger co-founder David Balland and his partner were kidnapped in France and held for ransom before police freed them, one of a growing number of physical "wrench attacks" on people known or believed to hold crypto.

Trezor, 2022 to 2026.

Trezor's customers have been repeatedly targeted through the company's vendors. In April 2022 a breach at the email platform Mailchimp was used to send phishing to Trezor users. In January 2024, an attacker accessed Trezor's third-party support ticketing portal, potentially exposing names and emails of up to 66,000 people who had contacted support since December 2021; at least 41 were promptly emailed requests for their seed information. In August 2026 Trezor disclosed that a breach at its shipping provider ShipMonk had exposed order data, and a follow-up investigation raised the total to about 81,000 customers with names, shipping addresses, phone numbers, and emails. Then on September 9, 2026, attackers who had breached Brevo, Trezor's newsletter provider, sent phishing from Trezor's legitimate sending infrastructure to about 347,000 subscribers. The lure claimed an STM32 entropy vulnerability, capitalizing on the real Coldcard news weeks earlier, and pushed recipients toward an app that asked for their wallet backup. Trezor took the malicious domain down within about 20 minutes, but roughly 2,500 people had already clicked.

LESSON FOR BUILDERS

Your customer list is a list of targets, and every vendor that touches it (store platform, shipping, support desk, newsletter tool) is part of your attack surface. Collect the minimum, purge order data on a schedule, keep shipping and support data segregated, and audit vendor access regularly. Plan for the day an attacker sends email from your real domain: train users that no legitimate message will ever ask for a seed, and build your product so that this rule has no exceptions.

LESSON FOR HOLDERS

Expect your name and address to leak eventually if you buy a hardware wallet. Consider shipping to a location that is not your home, never discuss holdings publicly, and treat any unsolicited device, "replacement," or urgent security alert as an attack, even if it arrives from the vendor's real email address or in genuine-looking packaging. A real hardware wallet company will never ask you to type your recovery phrase into anything.

Software supply chain: the code that talks to the device

Ledger Connect Kit, December 2023.

Ledger Connect Kit was a JavaScript library that decentralized applications used to connect to Ledger devices. Many integrations used a loader that fetched the latest version of the kit from a content delivery network at runtime, so updates reached users without each dApp shipping a new build. On the morning of December 14, 2023, an attacker phished a former Ledger employee and hijacked his still-active npm account using a session token that bypassed two-factor authentication. Ledger had revoked the former employee's access to GitHub, single sign-on, and internal tools, but not to npm.

The attacker published three malicious versions (1.1.5, 1.1.6, and 1.1.7) containing a wallet drainer that used a rogue WalletConnect project to route funds to the attacker. Because of the runtime loader, dApps including well-known DeFi front ends began serving the drainer automatically. Ledger deployed a clean version within about 40 minutes of learning of the attack, but caching kept the malicious file available for roughly five hours, with draining concentrated in about two. Losses were estimated at around \$600,000, and Tether froze the attacker's USDT. Notably, the device itself worked exactly as designed. Users were tricked into approving malicious transactions they could not meaningfully read on their device screens.

Fake companion apps.

In November 2023, a counterfeit Ledger Live app distributed through the Microsoft Store was linked to about \$768,000 in stolen assets. Fake companion apps have appeared repeatedly in official app stores and search ads, and they all work the same way: they look like the real thing and ask for the recovery phrase.

LESSON FOR BUILDERS

Pin exact dependency versions and never load signing-path code from a CDN at runtime; if you must, use Subresource Integrity hashes. Require hardware-key 2FA on package registries, enable provenance and publishing restrictions, and make offboarding revoke every registry token, CI secret, and cloud credential, not just SSO. Monitor your package names and your brand in app stores for impersonation.

Trust and communication: Ledger Recover, May 2023

On May 16, 2023, Ledger announced Ledger Recover, an optional paid service that would split an encrypted copy of a user's seed into three shards held by Ledger, Coincover, and EscrowTech, recoverable after an identity check. The update shipped in Nano X firmware 2.2.1. The cryptography was reasonable, and many users genuinely lose seeds. The backlash was about something else: for years, users had understood that their seed could never leave the device, and the announcement demonstrated that signed firmware could, in fact, export it. Critics pointed out that the relevant code was closed-source and that the service depended on identity verification. CEO Pascal Gauthier acknowledged that governments could, in principle, compel the custodians to hand over shards. Ledger paused the rollout on May 23, committed to open-sourcing more of its code, and later offered the service on an opt-in basis.

Ledger co-founder Nicolas Bacca argued that the feature did not change the security assumptions compared to any firmware update, and technically he had a point: a user of any closed-firmware device was always trusting the vendor not to ship a key-exporting update. The episode is instructive precisely because it made that implicit trust explicit.

LESSON FOR BUILDERS

Your users' threat model is built on what you have told them. If a feature changes what the device can do with the seed, explain it before you ship it, publish the code, and make the capability opt-in at the firmware level rather than only at the service level. Marketing claims become security assumptions that users rely on.

6. When the Human and Operational Layer Was the Weak Link

A hardware wallet protects the key. It cannot protect a person who approves the wrong transaction, types the seed into a website, or loses the backup. The largest dollar losses involving hardware wallets have come from this layer.

Bybit, February 2025: \$1.5 billion signed on hardware wallets

Bybit stored a large amount of ETH in a Safe multisignature cold wallet whose signers approved transactions with Ledger hardware devices, the kind of setup widely regarded as best practice. On February 21, 2025, during what the signers believed was a routine transfer from cold to hot wallet, they approved a transaction that instead handed control of the wallet to the attacker. Roughly \$1.5 billion in ETH and staked ETH was drained, the largest single theft in crypto history. The FBI attributed the attack to North Korea's Lazarus Group.

Forensic investigations by Sygnia and Verichains found that the attackers had compromised a Safe{Wallet} developer's machine weeks earlier and used that access to plant malicious JavaScript in the Safe web interface served from Safe's cloud storage. The code activated only for Bybit's wallet. The web interface showed the signers a normal transfer, while the data actually sent to their devices was a different call that replaced the wallet's underlying contract logic. The hardware wallets could not decode that call into something a human could check, so the signers "blind signed" an opaque payload. Two minutes after the theft, the attackers replaced the malicious script with a clean one to cover their tracks.

Every signer used a hardware wallet, and every signer used the same compromised interface to decide what to approve. The multisig requirement provided no independence because all three approvals rested on a single source of truth.

LESSON FOR BUILDERS

If a device shows the user a hash or a raw blob, it is not protecting them. Decode and display what a transaction will actually do (recipient, amount, contract method, and especially delegatecalls, ownership changes, approvals, and upgrades), and refuse or loudly warn on anything that cannot be decoded. Support structured clear-signing standards (Ledger's clear-signing effort produced ERC-7730), and design multisig flows so signers verify independently, ideally with separate software, separately computed transaction hashes, and simulation.

Seed phishing and the never-type-your-seed rule

Across the Ledger and Trezor incidents described above, the overwhelming majority of actual theft did not require defeating the hardware at all. It required convincing a person to type their recovery phrase into a computer, phone, or website. Fake apps, fake support agents, fake replacement devices, fake "security upgrades," and fake firmware alerts all converge on the same request, because the recovery phrase is the one thing that bypasses every protection the device offers.

Loss without theft

Not every loss involves an attacker. People forget PINs, lose or destroy recovery sheets, store a single backup in a place that floods or burns, or die without passing on enough information for heirs to recover funds. Joe Grand's 2021 recovery made headlines precisely because it was so rare; for the vast majority of people who lose both PIN and seed, the funds are gone permanently. Ironically, the same physical weakness that let Grand rescue those funds would have let a thief steal them.

Address verification and the compromised host

Clipboard-hijacking malware has long swapped copied addresses for attacker addresses, and "address poisoning" plants look-alike addresses in a victim's transaction history in the hope they will be copied later. A hardware wallet defeats these attacks only if the user compares the full address shown on the device's own screen with the intended recipient, using a source other than the possibly compromised computer.

LESSON FOR HOLDERS

Verify on the device, not on the computer. Read the full address and amount on the hardware wallet's own screen. If the device cannot show you what a transaction does, do not approve it for any amount you cannot afford to lose. For large transfers, send a small test first and confirm it arrived.

7. Consolidated Lessons for Builders

The table below maps recurring failure modes to the incidents that demonstrated them and the defenses that would have reduced the damage. None of these failures were exotic. Most were ordinary engineering and operational mistakes made in a domain where a single mistake is directly convertible into irreversible loss.

Failure mode	Where it happened	What to do instead
Weak or silently broken entropy	Coldcard (2021 to 2026); Libbitcoin Explorer "Milk Sad" (2023)	Test that the hardware RNG is actually on the seed path; treat build flags as security code; mix independent sources; support dice; have a seed-migration plan.
Secrets extractable with physical access	Trezor and KeepKey glitching (2019 to 2022)	Use fault-resistant secure storage; never let a short PIN alone protect the seed; audit update and recovery paths for secret copies; support passphrases.
Broken trust boundary between chips	Ledger Nano S (2018)	The trust anchor must verify everything that controls the display and buttons; assume intermediate chips can lie.
Malicious or tampered firmware	Dark Skippy (2024); Rashid supply-chain attack (2018)	Signed firmware with anti-rollback; reproducible builds users can verify; anti-exfil signing; device attestation.

Failure mode	Where it happened	What to do instead
Blind signing	Bybit (2025); Ledger Connect Kit (2023)	Decode and display intent on the device; warn or refuse on undecodable data; support clear-signing metadata; independent verification for multisig.
Runtime-loaded or hijacked dependencies	Ledger Connect Kit (2023); Safe{Wallet} front end (2025)	Pin versions; no runtime CDN loading on signing paths; SRI hashes; hardware 2FA and provenance on registries; full credential revocation on offboarding.
Customer data as a target list	Ledger (2020); Trezor (2024, 2026); KeepKey (2016)	Minimize and purge data; vet and monitor vendors; segregate shipping and support data; prepare users for phishing from your real domain.
Trust-model changes without transparency	Ledger Recover (2023)	Announce before shipping; publish code; make capabilities opt-in at the firmware level; align marketing with the actual threat model.
Dismissing researchers	Ledger and Rashid (2018)	Run a responsive bounty program; treat practical-sounding reports as practical until proven otherwise; credit researchers publicly.

Three principles underlie the table. First, the device's screen is the only trustworthy interface; everything your software shows on a computer or phone should be treated as potentially attacker-controlled, and your design should make the device screen sufficient for a careful user to catch an attack. Second, every component between the user's intent and the signature (the front end, the connector library, the package registry, the build configuration, the RNG wrapper) is part of the security boundary, whether or not it is in your repository. Third, the people and vendors around the product are attack surface: offboarding, vendor access, and customer data handling have caused as much harm as cryptographic bugs.

8. Consolidated Lessons for Holders

Practice	Why history says it matters
Buy directly from the manufacturer and never use an unsolicited or "replacement" device.	Supply-chain attacks (2018) and mailed fake Nano X devices (2021) both relied on devices from outside the official channel.
Never type your recovery phrase into a computer, phone, website, or app, for any reason.	Fake Ledger Live apps, support-portal phishing, and the 2026 Brevo campaign all ended with a request for the seed.
Verify the address, amount, and action on the device screen, and refuse to blind sign.	Bybit's signers and Connect Kit victims approved transactions whose real effect they could not see.
Use a passphrase, and for large holdings, multisig across different vendors.	Passphrases blunted glitching attacks (2020); vendor diversity would have contained the Coldcard entropy failure (2026).
Know how and when your seed was generated; migrate when a generation flaw is announced.	Coldcard seeds created on affected firmware stayed vulnerable after the patch; only moving funds helped.
Keep firmware current, but only through the vendor's official app, never through a link in an email.	Phishers sent fake "critical security alerts" from Trezor's real email infrastructure in 2026.
Make durable, tested, geographically separated backups and an inheritance plan.	Lost PINs and seeds are permanent for almost everyone; Joe Grand-style rescues are the rare exception.
Protect your privacy: limit who knows what you hold and where you live.	Leaked customer addresses led to extortion threats and contributed to a climate of physical attacks.
Send a small test transaction before a large one.	Catches address substitution and configuration mistakes before they are expensive.

Closing Thought

Hardware wallets did what they were invented to do. The era when a single malware infection on a home computer could silently empty a fortune is largely over for people who use them correctly. But the history since 2014 shows the risk did not disappear; it moved. It moved into the random number generator, into the trust boundary between chips, into JavaScript loaded from a CDN, into a web interface the signers trusted, into marketing databases and support desks, and into the moment a frightened person reads an urgent email. For builders, the job is to keep shrinking the set of things that must go right for the user to stay safe. For holders, the job is to understand that the device is one layer of protection, and to make sure the other layers are not where the loss happens.

9. Sources

Primary disclosures from the companies and researchers involved were preferred where available. Figures for 2026 incidents come from contemporaneous reporting and on-chain analysis and may be revised.

Trezor Blog. "How TREZOR Was Born from a Hacking Attack That Affected Slush Pool." blog.trezor.io

Trezor Blog. "7 Years of Hardware Wallets: The Success Story of Czech Crypto Enthusiasts." blog.trezor.io

SatoshiLabs. Press kit and company history. satoshilabs.com/presskit

Bitcoin Wiki. "List of Major Bitcoin Heists, Thefts, and Losses." en.bitcoin.it

Bitcoin.com / Kai Sedgwick. "Bitcoin History Part 7: The First Major Hack" (allinvain, 2011).

ESET WeLiveSecurity (2011) and Symantec reporting on Infostealer.Coinbit.

SiliconANGLE (Mar 2, 2012) and Bitcoin Magazine coverage of the Linode / Bitcoinica thefts.

View from the Back, "French Fancies: Ledger" (2026); CryptoActu, "Qu'est-ce que Ledger ?" (2026); WeUseCoins profile of Eric Larchevêque.

GeekWire, "KeepKey LLC" Startup Spotlight (2016); KeepKey, About page and company history. keepkey.com

Ivey Business School, Coinkite company profile (2018); Coinkite / COLDCARD about page; Coinkite PSBT post to bitcoin-dev (June 2018).

Saleem Rashid. "Breaking the Ledger Security Model" (Mar 20, 2018); Ledger Donjon Security Bulletin LSB-002; KrebsOnSecurity (Mar 2018).

The Block and Hackaday coverage of Kraken Security Labs' Trezor research (Jan 31, 2020).

Cointelegraph, The Verge, and FXEmpire coverage of Joe Grand's Trezor One recovery (Jan 2022).

Bitcoin Optech Newsletter (Aug 9, 2024) on Dark Skipky; disclosure posts by Nick Farrow and Lloyd Fournier.

TRM Labs. "The Largest Hardware Wallet Exploit of 2026: Inside the USD 116 Million Coldcard Hack" (Aug 5, 2026).

The Hacker News, "Coldcard Hardware Wallet Flaw Linked to \$70 Million Bitcoin Theft" (Aug 2026); Bitcoin.com News; fystack.io analysis.

Ledger. "Update: Efforts to Protect Your Data and Prosecute the Scammers" (Jan 2021); Decrypt and CoinDesk coverage of the Ledger data breach.

BleepingComputer, Bitdefender, and Nasdaq/Bitcoin Magazine coverage of fake Ledger Nano X devices (June 2021).

The Block. "Ledger defends crypto wallet recovery tool" (May 16, 2023); Cointelegraph and Forklog coverage of Ledger Recover.

Ledger. "Security Incident Report" on Connect Kit (Dec 20, 2023); The Hacker News and TechRadar coverage.

Forklog coverage of the counterfeit Ledger Live app on the Microsoft Store (2023).

Trezor. "Security update: stay vigilant against potential phishing attack" (Jan 20, 2024).

BleepingComputer. "Trezor: 347,000 users targeted in phishing attacks after Brevo breach" (Sep 11, 2026); Unchained coverage of the ShipMonk breach.

The Block, BleepingComputer, and FBI IC3 PSA250226 on the Bybit / Safe{Wallet} attack (Feb 2025).

CoinAcademy coverage of the kidnapping of David Balland (2025).